

Security+ 5.1 · Data Roles & Responsibilities

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 5.1 — Data Roles & Responsibilities (2:27)** · [Vídeo no YouTube ↗](#)

Resumo da Aula: Owner (negócio — define classificação/who accesses — o GERENTE); Controller (determina o PROPÓSITO e uso legal — LGPD/GDPR); Processor (processa em nome do controller — cloud provider); Custodian (TI — ADMINISTRA/implementa o owner pede).

Highlights que a prova cobra

- Owner=gerente do negócio (define); Custodian=TI (implementa)
- Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM

Dicas de prova & Cenários Típicos

- 'the person who determines how data is used'=data controller

Cenário clássico de exame: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH).

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 5.1)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Data Roles & Responsibilities) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Estratégias de Tratamento de Risco:**
 - **Mitigação/Redução:** aplicar controles técnicos ou administrativos para diminuir probabilidade ou impacto (ex: instalar EDR).
 - **Transferência/Compartilhamento:** repassar o impacto financeiro para um terceiro (ex: contratar seguro cibernético ou terceirizar para um MSSP).
 - **Aceitação:** reconhecer o risco quando o custo do controle supera o valor do ativo (exige aprovação formal da alta liderança).
 - **Evitação:** cancelar ou não iniciar a atividade arriscada (ex: descontinuar um serviço legado inseguro).
- **Métricas de Risco e Análise Quantitativa:**
 - **SLE (Single Loss Expectancy):** perda financeira estimada para uma única ocorrência do incidente ($\text{Asset Value} \times \text{Exposure Factor}$).
 - **ARO (Annualized Rate of Occurrence):** frequência anual estimada do evento.
 - **ALE (Annualized Loss Expectancy):** custo anualizado total do risco: $\text{ALE} = \text{SLE} \times \text{ARO}$.
- **Métricas de Continuidade de Negócios (BCP / DRP):**
 - **RTO (Recovery Time Objective):** tempo máximo tolerável que o sistema pode ficar inoperante após um desastre.
 - **RPO (Recovery Point Objective):** volume máximo de dados que a organização tolera perder, medido em tempo (ex: se o backup é diário, o RPO é de até 24 horas de transações perdidas).
 - **MTBF (Mean Time Between Failures):** tempo médio em que um equipamento opera sem falhas.
 - **MTTR (Mean Time to Repair):** tempo médio necessário para consertar ou substituir um componente com defeito.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Se a questão disser 'contratar apólice de seguro contra ataques cibernéticos' = **Transferência de Risco** (nunca mitigação).
- RPO define a frequência dos backups; RTO define a velocidade da infraestrutura de restauração e failover.

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. `a = 5\nb = 3\na, b = b, a\nprint(a - b)`

- A)** 2
- B)** -2
- C)** 8
- D)** 0

2. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'Owner=gerente do negócio (define); Custodian=TI (implementa)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Owner=gerente do negócio (define); Custodian=TI (implementa)...

3. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'the person who determines how data is used'=data controller'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'the person who determines how data is used'=data controller...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH)....
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'Owner=gerente do negócio (define); Custodian=TI (implementa)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Owner=gerente do negócio (define); Custodian=TI (implementa)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'the person who determines how data is used'=data controller'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'the person who determines how data is used'=data controller...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH)....

10. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'Owner=gerente do negócio (define); Custodian=TI (implementa)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Owner=gerente do negócio (define); Custodian=TI (implementa)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) B — -2.

✓ **Por que está certa:** Troca de valores: a vira 3 e b vira 5. $3 - 5 = -2$.

✗ **Por que as outras estão erradas:**

- 2: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- 8: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- 0: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) D — Implementar a solução correspondente: Owner=gerente do negócio (define); Custodian=TI (implementa)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): Owner=gerente do negócio (define); Custodian=TI (implementa).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) A — Implementar a solução correspondente: Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: 'the person who determines how data is used'=data controller....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): 'the person who determines how data is used'=data

controller.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) A — Implementar a solução correspondente: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH).....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): 'gerente de RH define quem acessa dados de funcionários'=data owner (RH)..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: Owner=gerente do negócio (define); Custodian=TI (implementa)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): Owner=gerente do negócio (define); Custodian=TI (implementa).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): Controller (LGPD) define o PORQUÊ; Processor

processa POR ORDEM.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: 'the person who determines how data is used'=data controller....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): 'the person who determines how data is used'=data controller.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH).....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): 'gerente de RH define quem acessa dados de funcionários'=data owner (RH)..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) B — Implementar a solução correspondente: Owner=gerente do negócio (define); Custodian=TI (implementa)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): Owner=gerente do negócio (define); Custodian=TI

(implementa).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.